

Regulation and Compliance

CompTIA PenTest+ (PT0-003)

Domain: 1.0: Engagement Management

Objective: 1.1: Summarize pre-engagement activities.

Video Overview

This video introduces key regulations and compliance frameworks that are essential for penetration testing. As you watch, you'll see how understanding these standards—from protecting sensitive financial data to safeguarding personal information—is not just about meeting legal requirements, but about conducting responsible and effective security assessments in the real world. This knowledge is directly applicable to your future career as a penetration tester, where adhering to these guidelines will be fundamental to every engagement.

Key Topics Covered

- **Payment Card Industry Data Security Standard (PCI-DSS):** Controls for cardholder data, merchant levels, and compliance requirements, including Requirement 11 (testing security systems and processes).
- **General Data Protection Regulation (GDPR):** Standards for lawful data processing, relevant articles (Article 32 for security assessments and Article 35 for Data Protection Impact Assessments), and applicability to EU-based organizations.
- **Health Insurance Portability and Accountability Act (HIPAA):** Regulation for protecting patient health information.
- **Sarbanes-Oxley Act (SOX):** Regulation concerning financial reporting and preventing fraud.
- **National Institute of Standards and Technology (NIST):** Cybersecurity framework guidelines.
- **ISO 27001:** International standard for information security management systems.

Student Notes Section